

Step	Procedure	Command
1	Create the project directory	mkdir secure-cicd && cd secure-cicd
2	Initialize Git repository	git init
3	Set the main branch	git branch -M main
4	Initialize Node.js project	npm init -y
5	Create a sample application	echo "console.log('Secure CI/CD Demo');" > app.js
6	Test the application	node app.js
7	Add project files to Git	git add .
8	Commit the project	git commit -m "Initial secure CI/CD project"
9	Connect the GitHub repository	git remote add origin https://github.com/SMRUTI727/secure-cicd.git
10	Push the project to GitHub	git push -u origin main
11	Create the GitHub Actions workflow directory	mkdir -p .github/workflows
12	Create the CI/CD workflow file	nano .github/workflows/security.yml
13	Install project dependencies and create lockfile	npm install
14	Perform dependency vulnerability scanning	npm audit
15	Generate npm Audit report	npm audit --json > npm-audit.json
16	Install/check Gitleaks	gitleaks version
17	Scan the project for exposed secrets	gitleaks detect --source . --verbose
18	Generate Gitleaks report	gitleaks detect --source . --report-format json --report-

		path gitleaks-report.json
19	Start SonarQube using Docker	docker run -d --name sonarqube -p 9000:9000 sonarqube:community
20	Verify SonarQube container	docker ps
21	Open SonarQube	http://localhost:9000
22	Create Secure CI/CD project in SonarQube	Project key: secure-cicd
23	Pull OWASP ZAP Docker image	docker pull ghcr.io/zaproxy/zaproxy:stable
24	Run ZAP baseline scan (<i>if web app is running</i>)	docker run --rm -t ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t http://host.docker.internal:3000
25	Commit security reports/configuration	git add . && git commit -m "Add security scanning"
26	Push changes to GitHub	git push origin main
27	Verify CI/CD execution	Open GitHub → secure-cicd → Actions

Output

```

kali@kali: ~/secure-cicd
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
└─$ mkdir secure-cicd
(kali@kali)-[~]
└─$ cd secure-cicd
(kali@kali)-[~/secure-cicd]
└─$ git init
hint: Using 'master' as the name for the initial branch. This default branch name
hint: will change to "main" in Git 3.0. To configure the initial branch name
hint: to use in all of your new repositories, which will suppress this warning,
hint: call:
hint:   git config --global init.defaultBranch <name>
hint: Names commonly chosen instead of 'master' are 'main', 'trunk' and
hint: 'development'. The just-created branch can be renamed via this command:
hint:   git branch -m <name>
hint: Disable this message with "git config set advice.defaultBranchName false"
Initialized empty Git repository in /home/kali/secure-cicd/.git/
(kali@kali)-[~/secure-cicd]
└─$ git branch -M main
(kali@kali)-[~/secure-cicd]
└─$ npm init -y
Wrote to /home/kali/secure-cicd/package.json:

```

error: failed to push some refs to 'https://github.com/SMRUTI727/secure-cicd.git'

```
(kali@kali)-[~/secure-cicd]
```

```
$ cd ~/secure-cicd
```

```
(kali@kali)-[~/secure-cicd]
```

```
$ git remote set-url origin git@github.com:SMRUTI727/secure-cicd.git
```

```
(kali@kali)-[~/secure-cicd]
```

```
$ git remote -v
```

```
origin git@github.com:SMRUTI727/secure-cicd.git (fetch)
```

```
origin git@github.com:SMRUTI727/secure-cicd.git (push)
```

```
(kali@kali)-[~/secure-cicd]
```

```
$ ssh -T git@github.com
```

The authenticity of host 'github.com (20.207.73.82)' can't be established.

ED25519 key fingerprint is: SHA256:+DiY3wvvV6TuJJhpZisF/zLDA0zPMSvHdkr4UvC0qu

This key is not known by any other names.

Are you sure you want to continue connecting (yes/no/[fingerprint])? yes

Warning: Permanently added 'github.com' (ED25519) to the list of known hosts.

Hi SMRUTI727! You've successfully authenticated, but GitHub does not provide shell access.

```
(kali@kali)-[~/secure-cicd]
```

```
$ git push -u origin main
```

Enumerating objects: 6, done.

Counting objects: 100% (6/6), done.

Delta compression using up to 4 threads

Compressing objects: 100% (3/3), done.

Writing objects: 100% (5/5), 662 bytes | 331.00 KiB/s, done.

Total 5 (delta 1), reused 0 (delta 0), pack-reused 0 (from 0)

remote: Resolving deltas: 100% (1/1), completed with 1 local object.

To github.com:SMRUTI727/secure-cicd.git

908f266..d8c8f3e main -> main

branch 'main' set up to track 'origin/main'.

```
(kali@kali)-[~/secure-cicd]
```

```
$ sudo apt install gitleaks
```

```
kali@kali: ~/secure-cicd
Session Actions Edit View Help

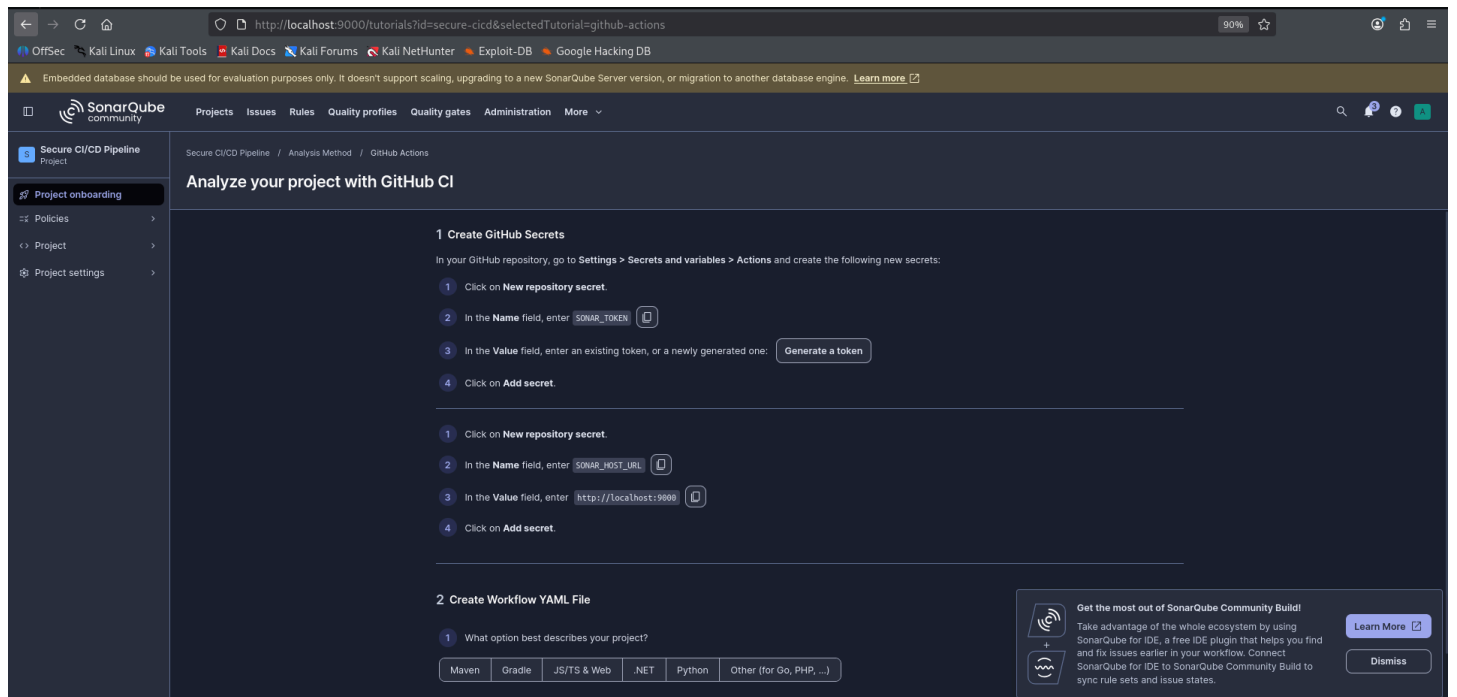
(kali@kali)-[~/secure-cicd]
$ sudo usermod -aG docker $USER

(kali@kali)-[~/secure-cicd]
$ newgrp docker
zsh: corrupt history file /home/kali/.zsh_history

(kali@kali)-[~/secure-cicd]
$ docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS        NAMES
040363fcded1   sonarqube:community   "/opt/sonarqube/dock..."   15 minutes ago   Up 15 minutes   0.0.0.0:9000->9000/tcp, [::]:9000->9000/tcp   sonarqube

(kali@kali)-[~/secure-cicd]
$ docker run -d \
  --name sonarqube \
  -p 9000:9000 \
  sonarqube:community
Unable to find image 'sonarqube:community' locally
community: Pulling from library/sonarqube
e51aee9c82ec: Pull complete
e218a9dbc888: Pull complete
9c52eaa0e70e: Pull complete
4f4fb700ef54: Pull complete
0911b38078c5: Pull complete
0d4fc3d8b0c5: Pull complete
58c8347a0923: Pull complete
Digest: sha256:aa7146fd72ef79ea8ca06315ca3121db9bb1c24a83ba5255e8df67b43dee6e04
Status: Downloaded newer image for sonarqube:community
040363fcded10318d208b5fa9fa3902da553ad28c5454cbbb1126014b9f11f3f

(kali@kali)-[~/secure-cicd]
$ docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS        NAMES
040363fcded1   sonarqube:community   "/opt/sonarqube/dock..."   15 minutes ago   Up 15 minutes   0.0.0.0:9000->9000/tcp, [::]:9000->9000/tcp   sonarqube
```



```
(kali㉿kali)-[~]
└─$ cd ~/secure-cicd
(kali㉿kali)-[~/secure-cicd]
└─$ npm install
up to date, audited 1 package in 591ms
found 0 vulnerabilities
(kali㉿kali)-[~/secure-cicd]
└─$ npm audit
found 0 vulnerabilities
(kali㉿kali)-[~/secure-cicd]
└─$ npm audit --json > npm-audit.json
(kali㉿kali)-[~/secure-cicd]
└─$ ls -lh npm-audit.json
-rw-rw-r-- 1 kali kali 358 Sep 12 13:33 npm-audit.json
(kali㉿kali)-[~/secure-cicd]
└─$ npm audit fix
up to date, audited 1 package in 370ms
found 0 vulnerabilities
(kali㉿kali)-[~/secure-cicd]
└─$
```

